IFESEC

Ijezie Risk Advisory

AtlasPay

SOC 2 Type 1 Risk Register

Board-Ready Appendix

Prepared for: AtlasPay, Inc. Board of Directors and Risk Committee
Framework: AICPA SOC 2 Trust Services Criteria, Revision 2022
Engagement: FinTech Payment Processor — SOC 2 Type 1 Readiness

Report date: 2026-06-25
Classification: INTERNAL // EXECUTIVE READY

Introduction

This risk register is the engagement's authoritative record of AtlasPay's exposure to information-security risk as of 2026-06-25. It is structured to support SOC 2 Type 1 audit readiness and to inform board-level risk governance.

Six risk scenarios are documented. Each scenario includes: a descriptive narrative; scoring on a 5x5 ISO 27005 quantitative matrix (AtlasPay 5x5, deployed in CISO Assistant v3.18.3); treatment plan; assigned owner; review cadence; and rationale for residual scoring.

Risk R-04 (Third-Party SaaS Breach) has been formally accepted at residual High by the Risk Committee. The acceptance statement and conditions are documented on the final page of this register.

Scoring Methodology

Probability scale (1-5): 1 = Unlikely (1-5%) · 2 = Rather unlikely (5-25%) · 3 = Likely (25-50%) · 4 = Very likely (50-80%) · 5 = Almost certain (80%+).

Impact scale (1-5): 1 = Minor (negligible) · 2 = Significant (limited) · 3 = Serious (substantial) · 4 = Critical (disastrous) · 5 = Catastrophic (sector or regulatory consequences beyond the organization).

Composite levels: The 5x5 matrix lookup returns one of: Very Low (1), Low (2), Medium (3), High (4), Very High (5). Treatment options: Mitigate, Accept, Transfer, Avoid.

Risk Register Summary

The table below summarizes all six risk scenarios with their engagement-finalized scoring. Detailed treatment plans and residual rationale follow on subsequent pages.

ID	Risk Scenario	Inherent	Current	Residual	Treatment
R-01	Privileged Account Compromise	Very High	Medium	Medium	Mitigate
R-02	Payment Data Exfiltration via API	Very High	Medium	Medium	Mitigate
R-03	Ransomware on Production Database Host	High	Medium	Medium	Mitigate
R-04	Third-Party SaaS Breach (Vendor Compromise)	High	High	High	Accept (with mitigation)
R-05	Insider Threat (Malicious Employee)	High	High	Medium	Mitigate
R-06	Insufficient Audit Logging	High	Low	Low	Mitigate

R-04 (Third-Party SaaS Breach) is highlighted in red because the residual risk is formally accepted by the Risk Committee. The acceptance statement and conditions appear on the final page of this register.

Residual Risk Distribution

Level	Count	Percentage	Risks
Very High	0	0%	—
High	1	17%	R-04 (accepted)
Medium	4	67%	R-01, R-02, R-03, R-05
Low	1	17%	R-06
Very Low	0	0%	—

Detailed Risk Scenarios

The following pages document each of the six risk scenarios with: scoring detail, treatment plan, assigned owner, review cadence, and rationale for residual scoring.

R-01 — Privileged Account Compromise

	Probability	Impact	Composite Level
Inherent	4 (Very likely)	5 (Catastrophic)	Very High
Current	2 (Rather unlikely)	5 (Catastrophic)	Medium
Residual	2 (Rather unlikely)	5 (Catastrophic)	Medium

Treatment	Mitigate
Owner	CISO
Review Cadence	Quarterly
Residual Rationale	PAM + MFA + quarterly reviews reduce probability; impact stays catastrophic because a compromised admin in FinTech is always catastrophic.

R-02 — Payment Data Exfiltration via API

	Probability	Impact	Composite Level
Inherent	4 (Very likely)	5 (Catastrophic)	Very High
Current	2 (Rather unlikely)	5 (Catastrophic)	Medium
Residual	2 (Rather unlikely)	5 (Catastrophic)	Medium

Treatment	Mitigate
Owner	CISO + CTO
Review Cadence	Quarterly
Residual Rationale	WAF + tokenization + API gateway with mTLS + quarterly pen testing maintain probability at 'rather unlikely'; impact stays catastrophic.

R-03 — Ransomware on Production Database Host

	Probability	Impact	Composite Level
Inherent	3 (Likely)	5 (Catastrophic)	High
Current	3 (Likely)	3 (Serious)	Medium
Residual	3 (Likely)	3 (Serious)	Medium

Treatment	Mitigate
Owner	CTO + CISO
Review Cadence	Quarterly
Residual Rationale	Immutable backups + EDR + tested restore procedure + quarterly recovery tests hold residual at Medium.

R-04 — Third-Party SaaS Breach (Vendor Compromise)

	Probability	Impact	Composite Level
Inherent	4 (Very likely)	4 (Critical)	High
Current	3 (Likely)	4 (Critical)	High
Residual	3 (Likely)	4 (Critical)	High

Treatment	Accept (with mitigation)
Owner	CISO + Vendor Management
Review Cadence	Quarterly
Residual Rationale	Supply-chain compromise is endemic in FinTech. TPRM program and contractual protections reduce blast radius but cannot reduce occurrence probability below 'likely'. Risk formally accepted by Risk Committee with conditions.

Risk Acceptance Statement

The Risk Committee has formally accepted residual High for R-04 (Third-Party SaaS Breach) with the following conditions:

(1) Quarterly vendor risk review with documented minutes;

(2) Annual SOC 2 Type 2 review for all Tier-1 vendors (V-01, V-02, V-03);

(3) Contractual sub-processor notification rights enforced;

(4) Annual tabletop exercise simulating vendor breach scenario;

(5) Cyber insurance policy maintained with vendor breach coverage.

If any of these conditions cannot be maintained, R-04 should be re-evaluated for treatment change (likely transfer via cyber insurance or escalate to board for risk avoidance discussion).

R-05 — Insider Threat (Malicious Employee)

	Probability	Impact	Composite Level
Inherent	4 (Very likely)	4 (Critical)	High
Current	3 (Likely)	4 (Critical)	High
Residual	2 (Rather unlikely)	4 (Critical)	Medium

Treatment	Mitigate
Owner	Head of People + CISO
Review Cadence	Quarterly
Residual Rationale	Background checks + RBAC + SoD + immutable audit logging + fast offboarding reduce probability from 'likely' to 'rather unlikely'.

R-06 — Insufficient Audit Logging

	Probability	Impact	Composite Level
Inherent	5 (Almost certain)	2 (Significant)	High
Current	2 (Rather unlikely)	2 (Significant)	Low
Residual	2 (Rather unlikely)	2 (Significant)	Low

Treatment	Mitigate
Owner	CISO + Engineering
Review Cadence	Quarterly
Residual Rationale	Centralized SIEM with 90-day hot retention + 6-year cold archive + alerting rules + immutable log forwarding.

Appendix: Scoring Matrix

All risk scoring uses the AtlasPay 5x5 matrix deployed in CISO Assistant v3.18.3 (URN: urn:atlaspay-5x5). The matrix is a 5x5 lookup table where rows represent probability (1-5) and columns represent impact (1-5). The cell at each intersection indicates the composite risk level.

Matrix Grid (AtlasPay 5x5)

	1-Minor	2-Significant	3-Serious	4-Critical	5-Catastrophic
5-Almost certain	2-Low	3-Medium	3-Medium	4-High	4-High
4-Very likely	2-Low	3-Medium	3-Medium	4-High	5-Very High
3-Likely	1-Very Low	2-Low	2-Low	3-Medium	3-Medium
2-Rather unlikely	1-Very Low	2-Low	2-Low	3-Medium	3-Medium
1-Unlikely	1-Very Low	1-Very Low	2-Low	2-Low	2-Low

Color key: Very Low (green) · Low (lime) · Medium (orange) · High (light red) · Very High (red).

Closing Notes

This risk register is the engagement's authoritative record of AtlasPay's exposure to information-security risk. The register is stored in CISO Assistant as the Risk Assessment RA-ATLASPAY-SOC2 within the AtlasPay folder.

> *Lab-synthetic disclaimer: The risk register values reflect consultant judgment for a portfolio demonstration engagement. In a real SOC 2 Type 1 readiness engagement, these values would be derived from AtlasPay's actual operational state, validated through interviews, observation, and inspection.*

IfeSec | Ijezie Risk Advisory